Модели угроз и их анализ

Что такое модель угроз?

• **Модель угроз** — это не просто список проблем.

Это структурированное описание того, как может быть нарушена безопасность вашей системы, какие последствия это может повлечь и какие меры защиты необходимы.

• Основные три компонента:

1. Угрозы
2. Атаки
3. Последствия

Основные этапы построения модели

1. Определить границы и характеристики системы.
2. Выявить возможные негативные последствия.
3. Определить объекты воздействия.
4. Определить источники угроз и модели нарушителей.
5. Определить способы реализации угроз.
6. Построить сценарии реализации угроз.
7. Определить актуальные угрозы и оформить результат.

Подходы к созданию моделей

- Стратифицированный анализ («слоеный пирог»)
- Сценарный подход («Что если…?»)
- Анализ уязвимостей
- SWOT-анализ (Strengths, Weaknesses, Opportunities, Threats)

Классификация угроз

- **По уровню воздействия:**

1. Критический (DDoS-атаки, кража данных)
2. Значительный (ВПО, фишинг)
3. Минимальный (ошибки конфигурации, слабые пароли)

- **По субъекту: кто осуществляет атаку?**

1. Внешние
2. Внутренние
3. Физические

Классификация угроз

- **По вектору атаки: как происходит?**

1. Сетевые (DDOS, сниффинг)
2. Прикладные (RCE, SQLi, XSS, CSRF)
3. Пользовательские (фишинг, соц. инженерия)
4. Физические (доступ к серверу)

- **По времени:**

1. Постоянные
2. Временные

Основные модели угроз

Модель	Автор/Описание	Применение
PDR (Protection-Defense-Recovery)	Традиционная модель защиты	Защита критической инфраструктуры
CIA-Triad Model	Конфиденциальность, целостность, доступность	Классификация требований безопасности
Stratisified Threat Model	Разделение по уровням системы	Сложные сети и приложения
MITRE ATT&CK	Глобальная база тактик атак	Анализ методов злоумышленников
NIST SP 800-30	Federal Risk Assessment Guide	Государственные стандарты США
ISO 27005/27019	Международные стандарты по рискам	Глобальная защита данных

Методы оценки рисков

Риск = Угроза × Уязвимость × Потенциальный ущерб

$$R = T \times V \times C$$

- T (Threat) — вероятность реализации угрозы
- V (Vulnerability) — уровень уязвимости системы
- C (Consequence) — возможный ущерб от инцидента

Методы оценки рисков

1. Матрица рисков (квалификационная)

Оценка происходит по осям: вероятность × воздействие.

Результаты закрашиваются цветом:

- 🟢 Зеленая зона — низкий риск (мониторинг)
- 🟡 Жёлтая зона — средний риск (планирование действий)
- 🔴 Красная зона — высокий риск (немедленные меры)

2. Qualitative Risk Assessment (качественная)

- Оценка экспертами
- Delphi-метод (анонимный опрос мнений от экспертов)
- Мозговой штурм

Методы оценки рисков

3. Quantitative Risk Assessment (количественная)

- Численная оценка в денежном эквиваленте
- Монте-Карло
- Анализ деревьев отказов

4. FMEA (Failure Mode and Effects Analysis)

- Анализ последствий отказов компонента
- Встроен в многие системы проектирования

Качественная оценка рисков — это процесс определения уровня риска с использованием экспертных суждений, опыта и классификационных шкал вместо точных числовых расчётов.

- **Оценка экспертами -** сбор мнения специалистов с опытом в ИБ

Техники проведения:

Дельфи-опрос (анонимный сбор мнений)

Индивидуальная консультация экспертов

Групповые обсуждения с модерацией

Применение: когда нет достаточных исторических данных

Плюсы: быстро, учитывает интуицию и опыт

Минусы: субъективность, влияние личных мнений

- **Delphi-метод -** анонимный многоэтапный процесс сбора мнений от экспертов с обратной связью до достижения консенсуса.

Преимущества Delphi-метода:

1. **Анонимность** — снижает влияние авторитета экспертов друг на друга
2. **Конструктивный диалог** — каждый может аргументировать мнение
3. **Стабильность** — достигается консенсус через несколько раундов

Этап	Действие
1	Подбор группы экспертов (7-15 человек)
2	Анонимное распределение вопросов по каждому риску
3	Сбор ответов через опросники/формуляры
4	Агрегация и анализ результатов
5	Обратная связь с аргументацией экспертов
6	Повторный раунд до стабилизации мнений

- **Мозговой штурм -** коллективное генерирование идей для выявления рисков. Пример:

Участник	Предложенная угроза	Оценка (после)
И.Иванов	Физический доступ к серверу	Риск = Средний
А.Петров	Социальная инженерия	Риск = Высокий
О.Сидоров	Утечка данных при разработке ПО	Риск = Высокий

Количественная оценка рисков — процесс оценки рисков с использованием численных значений, часто в денежном выражении. Требует исторических данных и статистического анализа.

- **Численная оценка в денежном эквиваленте**

$$R\ (Риск) = P(Вероятность) \times C(Потенциальный\ ущерб)$$

- **Анализ деревьев отказов**

Шаг	Действие
1	Определить нежелательное событие (топ-событие)
2	Выбрать основные пути к этому событию
3	Добавить промежуточные события (AND, OR, XOR гейты)
4	Заполнить листинг базовых событий
5	Рассчитать вероятность каждого сценария

- **Анализ Monte-Carlo** - статистический метод моделирования с использованием множества случайных вариаций параметров для прогнозирования диапазона возможных результатов.

1. Определяем распределения вероятностей для каждого параметра:
   - P(вероятность) ~ Нормальное распределение $\mu=0.2$, $\sigma=0.1$
2. Генерируем тысячи сценариев (обычно 1,000-10,000)
3. Суммируем результаты для каждого сценария
4. Строим распределение итоговых рисков

Проводится 10,000 симуляций → Получается диапазон возможных потерь.

- **FMEA** — метод анализа потенциальных модификаций отказа и их воздействия на систему или процесс. Широко используется в проектировании оборудования и ПО.
- Основные элементы:
  1. Субъект (сервер, приложение, человек)
  2. Режим отказа (авария, ошибка конфигурации)
  3. Воздействие (последствия отказа на систему в целом)
- Основные этапы:

  Шаг 1. Идентификация системы и компонентов

  Шаг 2. Определение режимов отказа (Modes)

  Шаг 3. Оценка последствий (Effects)

  Шаг 4. Ранжирование и приоритизация

Практический пример анализа

- **Объект:** интернет-магазин одежды с онлайн-оплатой

Шаг	Действие	Результат
1	Идентификация активов	БД пользователей, платежный шлюз, сервер приложений
2	Выявление угроз	Фишинг, DDoS, SQL-инъекции, утечки данных
3	Оценка уязвимостей	Недостаточное шифрование, открытый порт, слабые пароли
4	Расчёт рисков	$R = T \times V \times C$ для каждого сценария
5	Разработка контрмер	Шифрование, MFA, WAF, обучение персонала

Пример расчёта риска для платежной системы

- Угроза: Кража данных при перехвате транзакции

  T - 0,4 (вероятность перехвата через уязвимость API) × 70% (успешность) = 0,28

  V - Средняя уязвимость (парольная аутентификация) = 0,5

  C = $5,000,000 (потери клиентов + штрафы за потерю данных)

- Итоговый риск: R ≈ 0,28 × 0,5 × $5 млн = ~$700 тыс.

- Рекомендация: Высокий — внедрить двухфакторную аутентификацию

Пример матрицы рисков для интернет-магазина

Риск	Вероятность	Воздействие	Цвет	Приоритет
Фишинг	Высокая	Средний		Средний
DDoS на платежный шлюз	Средняя	Высокий		Высокий
Уязвимость в API	Высокая	Высокий		Высокий
Слабые пароли админов	Низкая	Средний		Мониторинг
Стихийное бедствие (пожар)	Очень низкая	Очень высокий		Страхование

Основные выводы

- Моделирование угроз — это проактивный подход к безопасности
- Комбинация нескольких моделей даёт лучший результат
- Оценка рисков требует учёта не только вероятности, но и последствий
- Практика важнее теории — применяйте инструменты на реальных кейсах

Домашнее задание

- Прочитать NIST SP 800-30 (руководство по оценке рисков)
- Изучить базовый документ MITRE ATT&CK
- Составить список из 5 угроз для системы, которую выберете сами, и оценить их по матрице рисков
- Подготовить короткий кейс анализа угрозы